

Quarterly Threat Report: Third Quarter, 2025

A majority of ransomware activity resulted from three leading groups. Beazley Security Labs also identified interesting trends with infostealers, including sophisticated techniques to deliver and obfuscate the malware,

along with new entrants rising to fill demand.



Executive Summary

In the third quarter, Beazley Security Labs observed interesting trends emerging in the ransomware cybercrime communities and advanced attack campaigns targeting vulnerabilities in very well-known technologies. During the quarter we also released new research describing a novel infostealer delivery method that went to great lengths to disguise malware with legitimate files. Unfortunately for one threat actor, our researchers exploited mistakes to take a rare look behind the curtain into a threat actors tooling and infrastructure. In this report, we'll describe the attack in detail, with links to the detailed research and analysis.

Additionally, several critical vulnerabilities were disclosed across major enterprise technologies in Q3, heightening risk to organizations and prompting Beazley Security Labs (BSL) to issue 38% more advisories to clients in response to active exploitation.

Continuing a Q2 trend, our investigations showed that use of compromised credentials remained the most leveraged entry point for ransomware attacks, and that attacks against publicly accessible VPN solutions enabled actors to access and exfiltrate data from victim environments. A contributor to high activity levels involved a prolonged campaign by the Akira ransomware group targeting SonicWall devices. Adding to SonicWall's misery this quarter was a significant breach of their cloud service, including sensitive configuration backups of client SonicWall devices.

Analysis of attack patterns across Beazley Security's Managed eXtended Detection and Response (MXDR) telemetry found an increased reliance on SEO and ad poisoning to trick end users. The technique allows attackers to deliver malware directly to victim endpoints, unlike traditional social engineering attacks such as credential theft enabled by phishing.

Following efforts such as [Operation ENDGAME](#) that disrupted major infostealer families, we observed new or lesser known infostealers emerge to fill demands in underground criminal markets. In August, for example, Beazley Security saw a surge in activity from Rhadamanthys infostealer, demonstrating ongoing demand for these commoditized services. Additional details are outlined later in this report.

This quarter’s report unpacks threat activity and trends and provides insights to help your organization strengthen preparedness for the remainder of 2025.

Q3 2025 Key Takeaways

- August and September showed a sharp increase in ransomware activity, with those months accounting for 26% and 18% of reported ransomware incidents the last half year, respectively.
- Akira, Qilin, and INC Ransomware represented 65% of all ransomware cases, demonstrating a significant increase in attack activity by the largest ransomware operators.
- Known Exploited Vulnerabilities tracked by the U.S Cybersecurity and Infrastructure Security Agency (CISA) fell by 26%, yet attackers executed several high-impact exploitation campaigns.
- Critical vulnerabilities in Cisco and NetScaler remote-access devices increasingly drew attention from attackers.
- Attacks on SonicWall devices by Akira ransomware group accelerated in Q3, followed by a prominent MySonicWall data breach impacting all organizations leveraging the backup cloud service.

Quarterly Ransomware Review

The comparison in reported ransomware incidents below (figure 1) illustrates how major business sectors have been affected by ransomware campaigns over time. Variations between quarters do not necessarily reflect a rise or fall in the overall threat of ransomware attack but can indicate evolution in threat actor targeting, as well as a victim’s appetite for disclosure when impacted by ransomware incidents.

Trends over the past two quarters indicate that the distribution of ransomware incidents across sectors has remained consistent, though certain sectors saw a higher concentration of reported activity.



Figure 1: Ransomware by Sector

Service-oriented sectors, such as business and professional services, continued to experience an increase in the number of ransomware incidents reported in Q3 of 2025. The trend suggests ransomware groups have been effective in targeting these organizations, while manufacturing, healthcare, and education segments have stayed relatively flat. Financial institutions, government entities, and retail experienced a slight drop in the relative volume of ransomware cases.

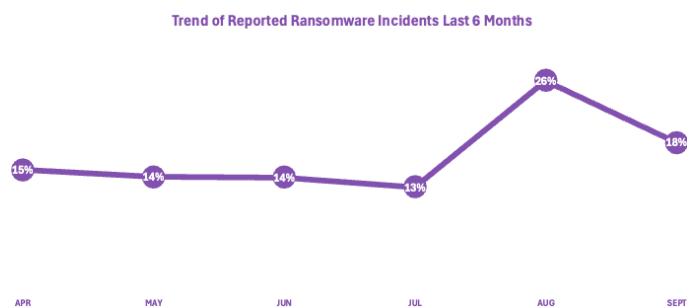


Figure 2: Ransomware Incidents Over Time

Figure 2 illustrates reported ransomware incident activity across the last six months. August saw a sharp uptick in reported incidents, with September maintaining an elevated level. The upward momentum of reported incidents aligns with a widespread campaign by the Akira ransomware operators, explained in detail later in this report.

As expected, activity monitored on threat actor leak sites increased in line with reported ransomware incidents, with leak site posts rising 11% from Q2 to Q3. These leak sites are operated by ransomware groups to pressure and extort victims into paying, and site volume can signal campaign activity across various actors.



Figure 3: Leaksite Activity

The data from leak sites, however, fails to account for any incidents that were not posted by the threat actor. Threat actors sometime choose to withhold specific organizations from their leak sites due to internal targeting decisions, quick ransom payment, or as part of “negotiations” with victim organizations. Leak site posts also suffer from lag, with days or weeks between compromise, negotiation processes, and finally public disclosure. This is sometimes signaled with a slight delay between reported incident spikes and leak site activity, as seen in the Q3 data. An incident reporting spike in August was followed by an increase in public leak site posts in September.

Notably, Qilin and Akira ransomware operators were the largest contributors to leak site disclosures monitored by Beazley Security Labs during Q3. Qilin accounted for 271 posts while Akira followed with 167 posts. This external activity closely aligns with Beazley Security’s Incident Response ransomware investigations for the period.

Ransomware Actors and Behaviors

Compared to investigations performed by Beazley Security last quarter, Q3 experienced a significant shift in ransomware attribution. Akira surged to account for the greatest proportion of ransomware cases Beazley Security investigated, more than 20 percent over the next most active group, Qilin. The dramatic increase in activity by Akira likely reflects the group's continued exploitation of SonicWall VPN vulnerabilities, which has enabled the group to effectively victimize organizations using those products.

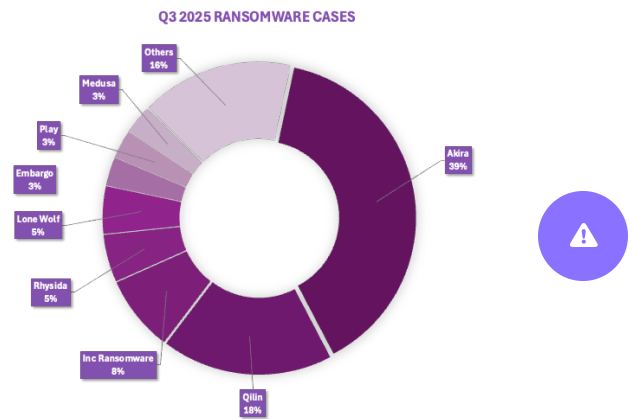


Figure 4: Distribution of Ransomware Threat Actors

We also saw a change in the concentration and distribution of threat actors involved with ransomware cases. The “Others” category, including lesser-known threat actors, shrank from 40% of cases last quarter to 16% in Q3. Notably, **the top three ransomware groups represented 65% of all cases, demonstrating a significant increase in attack activity by the largest ransomware operators.** This change may also suggest operational setbacks among the less capable or active groups during the quarter.

Of the ransomware actors observed by Beazley Security's incident responders, the three groups representing the largest share of investigations for the quarter are detailed below:

- **Akira**

Active since early 2023, Akira typically gains initial access by exploiting weaknesses in VPN appliances and remote services. In Q3 they broadly leveraged credential stuffing and brute force attacks, targeting unpatched systems or weak credentials opportunistically. Their increased activity this quarter in targeting SonicWall devices is detailed later in this report and is emblematic of this approach. They've capitalized on vulnerabilities in the devices to target various sectors including education, manufacturing, and IT. Akira accounted for approximately 39% of Beazley Security IR cases in Q3 and claimed 167 posts on their public leak site this quarter.

- **Qilin**

Also known as Agenda, Qilin was first observed by security researchers around July 2022. The group, like most modern ransomware operators, practice double extortion and exfiltrate data before encrypting it. The group ransoms both for decryption in the event victims don't have reliable backups and for the promise to delete stolen data when paid. They've been known to exploit victims through phishing emails, malicious attachments, and by abusing weak credentials

to gain access via remote desktop protocol (RDP) services. This quarter Beazley Security responders observed Qilin gain initial access into environments by brute forcing remote user VPN credentials and by abusing valid compromised credentials. The group is linked to many prominent cyberattacks, including a [recent high-profile incident targeting a Japanese beer manufacturer](#). Qilin accounted for approximately 18% of Beazley Security IR cases in Q3 and claimed 271 posts on their public leak site this quarter.



• **INC Ransomware**

INC Ransomware, known for deploying ransomware of the same name, was first observed in July 2023. The group uses a combination of phishing, credential theft, and opportunistic exploitation of exposed enterprise appliances to gain initial access. Since their inception, they’ve shown little discrimination in which sectors they attack, but recent activity has linked them to [attacks on healthcare organizations and public sector targets](#). INC Ransomware accounted for approximately 8% of Beazley Security IR cases in Q3 and claimed 119 posts on their public leak site this quarter. Beazley Security responders observed the group leverage valid, compromised credentials to access victim environments via VPN and Remote Desktop.

Initial Access Resulting in Ransomware Deployments

Initial access methods, such as the exploitation of exposed services, phishing, or use of stolen, valid credentials, can offer insight into tactics ransomware operators are using to gain initial access. By analyzing Beazley Security investigations, we can track shifts in operator trends to help identify opportunities to reduce risk.

As with Q2, our analysis concluded that the most common entry point was **the use of valid, compromised credentials to access VPN infrastructure**, which continued to grow in distribution this quarter. This trend underscores the importance of ensuring that multifactor authentication (MFA) is configured and protecting remote access solutions and that security teams maintain awareness and compensating controls for any accounts where MFA exceptions have been put in place.

Exploitation of internet-facing systems and services increased slightly while compromise through Remote Desktop Services (RDS) and supply chain attacks declined.

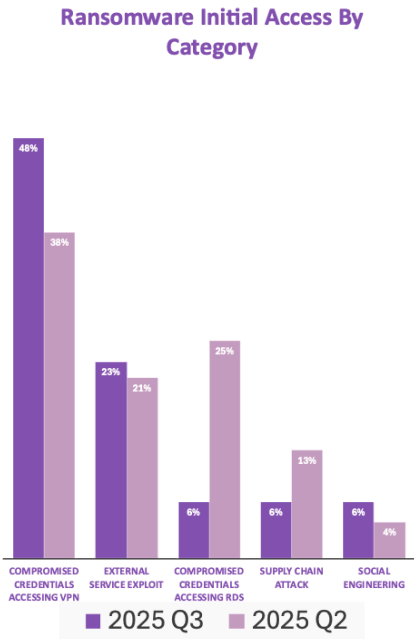


Figure 5: Initial Access by Category

While credential-based access to VPNs remained the most common entry point, a significant subset of investigations revealed a prolonged campaign from Akira ransomware operators compromising SonicWall security appliances. In cases where attribution was established, the group consistently gained access by using valid credentials in credential stuffing attacks against SonicWall SSLVPN services, exploiting weak access controls such as absent MFA and insufficient lockout policies on the device.



Compounding the mounting attacks against these appliances, SonicWall disclosed in late September that its [MySonicWall cloud backup service had been compromised](#). The compromised data included sensitive firewall configurations of every organization that opted in to the cloud backup service, including encrypted credentials which can be abused by threat actors to gain initial access. A detailed account of the SonicWall incidents and Akira’s campaign can be found in the Threat Landscape section of this report.

A smaller yet noteworthy subset of ransomware cases began via search engine optimization (SEO) poisoning attacks and malicious advertisements, observed as a method used for initial access in some Rhysida ransomware investigations. This technique places threat actor-controlled websites at the top of otherwise trusted search results, tricking users into downloading fake productivity and administrative tools such as PDF editors. These tools can be trojanized with various malware payloads, depending on threat actor objectives, and can potentially give threat actors a foothold directly on the endpoint in a network. The attack is effective because it bypasses other traditional social engineering protections like email filters that prevent phishing attacks. Other attack campaigns powered by this trojanized software have been observed by Beazley Security MDR teams and are documented in the Trends and Overview section below.

Beazley Security MDR Trends and Overview

Throughout Q3, Beazley Security’s MDR teams observed sustained adversary activity targeting clients. Each incident was mapped against the MITRE ATT&CK framework to provide visibility into adversary behavior and understand trending attack patterns.

Most observed activity occurred in the early to middle attack stages of MITRE’s attack lifecycle. This is where threat actors work to establish access, trick victims into executing malware to gain credentials, and move further into a network.

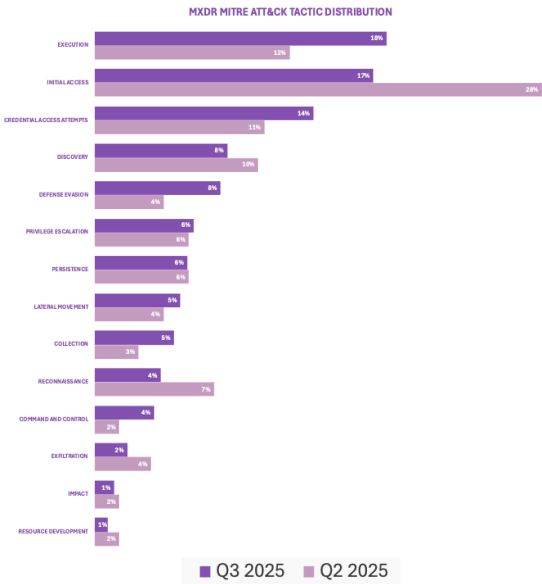


Figure 6: MITRE ATT&CK Tactics

The Q3 incident data shows an increased reliance on endpoint malware detonation, as reflected in the Execution category of the framework, with its occurrence rising compared to Q2. The trend signals that threat actors are shifting toward more aggressive methods. Rather than relying on traditional social engineering tactics, attackers are trying to gain a foothold by tricking victims into directly executing malware.



SEO Poisoning and Trojanized Tools

One of the observed contributors was the increasing effectiveness of **SEO poisoning campaigns**. SEO poisoning is a technique where threat actors manipulate search engine rankings to promote malicious or compromised websites at the top of search results. These malicious websites frequently mimic legitimate download pages for popular productivity and administrative tools.

The technique has been effective because it requires minimal victim interaction and exploits inherent trust in search engine results. These sites are developed to serve up trojanized versions of popular productivity and administrative tools such as PDF editors, remote access utilities, or collaboration tools. When victims download and execute the applications, the applications appear to function as expected while nefariously staging secondary persistence mechanisms. Some variants of the fake tools are even harder to detect by endpoint protection vendors because they do not immediately download or execute malicious payloads, but instead stage and install malware, such as infostealers, later via malicious updates. This stalling technique gives runway for more victims to download the malware before security vendors catch on, making the campaigns even more prolific.

This allows attackers to skip traditional reconnaissance steps to achieve malware execution. The result reinforces that it is essential to deploy a comprehensive set of security controls, including enhanced web browser filtering and end user awareness, to combat evolving tactics.

Throughout Q3, Beazley Security MDR teams observed several incidents where victims were tricked into downloading fake productivity tools, mostly in the form of PDF utilities, as threat actors launched waves of far-reaching SEO campaigns. Notably, the EvilAI campaign ([described in research by Trend Micro](#)) demonstrated how some attackers are embracing AI to generate code and skins to disguise malware. The fake tools were dressed up with names such as “Recipe Lister” and “PDF Editor” and distributed via SEO manipulation and malvertising. Threat actors have also been observed packaging the fake tools with valid digital signatures in attempt to further evade detection. For organizations, these threats highlight the need for in-depth protections such as web filtering, endpoint visibility, and organizational security awareness training to call out the campaigns.

Valid, Stolen Credentials

Credential access attempts also increased in distribution, aligning with threat actors leveraging stolen credentials from data breaches, using leaked security appliance configurations, and purchasing compromised credentials. As detailed above, many observed intrusions began with attackers using valid but compromised credentials. The pattern highlights how the commoditization of stolen credentials remains an effective approach for attackers to gain unauthorized access into a network. It also underscores the need for organizations to invest in security and harden their environments with modern identity controls. In the event an attacker obtains valid, compromised credentials, protections such as comprehensive MFA and conditional access policies help to reduce risk and can alert security teams of intrusion attempts.



Trends in Identifying Attacks

Mentioned above, adversarial behavior continues to evolve and MDR telemetry reveals a slight shift in our rollup of high-level attack stages over the last two quarters.

Attack Phase	Q2%	Q3%	Descriptions
Early-stage Attacks	58%	44%	Credential access attempts, recon, and discovery contained
Middle-stage Attacks	33%	44%	Attempts to sustain and expand adversarial access contained
Late-stage Attacks	9%	12%	High risk threats contained such as info-stealing, exfiltration, and ransomware deployment

Much like in Q2, the majority of MDR incidents were contained within the early and middle stages of attack. Notably there was a shift with more threats advancing to middle stage attack phases this quarter. The trend aligns with detection of malicious execution attempts on victim endpoints, many of which were triggered by a surge in SEO poisoning campaigns, sometimes leveraging fake software that “waits” to receive malicious updates in order to bypass traditional endpoint anti-malware solutions.

Vulnerability Trends and Overview

In Q3 2025, over 11,700 new vulnerabilities were publicly disclosed. Of these, **nearly 1,800 were considered high-risk**, meaning they could be exploited remotely and had potential to cause harm if unpatched.

Among these, **29 vulnerabilities** were confirmed to be actively exploited in the wild, according to the Cybersecurity and Infrastructure Security Agency (CISA). These “Known Exploited Vulnerabilities” (KEVs) are especially important because they represent real world threats and impacts.

Vulnerability Trends	Q3 2025	Change from Q2
New CVEs published by NIST	11,775	+ 0.1%
CVEs added to CISA KEV	29	- 26%
Critical 0-Day advisories published by BSL	11	+ 38%

***Critical BSL advisories are made publicly available [here](#).**

The third quarter saw continued activity with the number of newly published vulnerabilities remaining consistent with Q2, however the number of vulnerabilities added to CISA’s KEV dropped by 26%. While fewer vulnerabilities were confirmed as actively exploited by the authoritative source, it may not signal a reduction of risk. Although attackers may be targeting fewer vulnerabilities, the campaigns they are used in can be more impactful.

Beazley Security Labs (BSL) **published 11 zero-day (0-day) advisory responses, a 38% increase from Q2**. These types of vulnerabilities are exploited before vendors can release a fix and are often used in imminent, targeted campaigns.

A few impactful exploit campaigns that Beazley Security tracked in Q3 include:

- Microsoft SharePoint “ToolShell” 0-Day Vulnerability (CVE-2025-53770)**
A widely impactful vulnerability this quarter known as “ToolShell” affected installations of on-premises Microsoft SharePoint Server. The flaw allowed attackers to remotely execute code on vulnerable installations without requiring any authentication. The attack campaign worked by sending a specially crafted payload designed to exploit weaknesses in how SharePoint handled certain web request traffic. When successfully exploited, attackers would extract cryptographic keys from the server and then use them to further gain control of vulnerable sites, install webshells, and exfiltrate data. Microsoft released patches and recommended affected customers rotate their cryptographic keys. BSL published [this advisory](#) on the attack campaign.
- CrushFTP (CVE-2025-54309)**
Another critical vulnerability this quarter affected CrushFTP, an internet-facing secure file transfer platform widely used by organizations. CrushFTP support believed the attackers were

able to reverse engineer a prior patch to the product and discover a remote authentication bypass in a component often used for business-to-business file exchanges. Tracked as [CVE-2025-54309](#), this 0-day flaw allowed unauthenticated attackers to gain access to CrushFTP servers, data, and administrative functions within the software. This is not the first time CrushFTP has faced exploitation campaigns targeting critical vulnerabilities. Last quarter, [CVE-2025-31161](#) also allowed remote unauthenticated attacks to compromise the platform.



- **Attackers Exploit Critical Cisco Vulnerabilities in Campaigns**

In Q3, attackers increasingly targeted Cisco infrastructure and edge devices in campaigns to exploit flaws in remote access and network-based services. In one campaign, a sophisticated actor leveraged vulnerabilities ([CVE-2025-20333](#) and [CVE-2025-20363](#)) in Cisco ASA VPN components to gain unauthorized access into environments, resulting in CISA releasing this [directive](#) mandating U.S. federal agencies to submit core dumps of affected devices and check for signs of compromise.

Another campaign attacked a critical flaw in Cisco's underlying operating system (IOS) with a network management protocol enabled (SNMP). Cisco's incident response team confirmed successful exploitation of the vulnerability ([CVE-2025-20352](#)) in the wild, resulting in CISA adding it to the known exploited database (KEV). One documented campaign was later called "[Zero Disco](#)" and showed evidence of threat actors deploying rootkits on some affected Cisco network devices.

- **CITRIXBLEEDS (Again)**

Citrix NetScalers are a widely used perimeter network solution in enterprise environments, serving as a gateway between users and internal applications. The services help organizations manage and secure access to applications, cloud services, and remote desktops. Due to this, NetScaler services become a high-value target to attackers.

Two separate campaigns documented in recent BSL advisories indicate attackers repeatedly targeting the appliances to try and compromise organizations. The first, reported in late Q2, was named "[CitrixBleed 2](#)," due to its similarity in vulnerability to the first CitrixBleed incident in 2023, where attackers were able to extract sensitive session information and bypass authentication from a memory leak flaw (CVE-2023-4966).

The second, more recent flaw ([CVE-2025-7775](#)) allowed unauthenticated attackers the ability to execute code remotely on affected NetScalers with vulnerable configurations. Citrix confirmed active exploitation of the vulnerability in the wild on some NetScaler implementations, leading CISA to add the vulnerability to its KEV database and reports of webshell implants deployed on compromised appliances. Notably, CheckPoint [reported](#)

[observations](#) of threat actors discussing how to weaponize this vulnerability with assistance from offensive AI tooling to help recon efforts and generation of 0-day exploits.

While exploited vulnerabilities added to CISA’s KEV trended downward in Q3, the rise in attack campaigns tracked by Beazley Security Labs indicate that attackers are moving faster to exploit systems before vendors and system administrators can fix them. This resulted in larger-scale exploitation of critical enterprise services through the quarter.

The trend stresses the need for vulnerability management to be practiced as a continuous discipline, with organizations understanding and addressing severe vulnerabilities as quickly as possible. In some situations, that may mean implementing temporary mitigations or locking down network access until critical patches can be provided.

Additionally, organizations should assume that critically vulnerable devices that are exposed to the internet may have already been compromised, and to investigate appropriately.

Observations in the Threat Landscape

Infostealer Trends: From Operation ENDGAME to Rhadamanthys Surge

In Q2, Beazley Security tracked the impact of Operation ENDGAME, an international law enforcement effort targeting cybercriminal infrastructure. Led by Europol and Eurojust, the operation disrupted a subset of popular infostealer malware families, including LummaStealer and RedLine. These infostealers are commonly leveraged to exfiltrate credentials, browser data, and other sensitive information and often serve as a precursor to ransomware deployment.

Operation ENDGAME resulted in the takedown of over 300 servers and the seizure of millions in cryptocurrency. As a result, VirusTotal submission volumes for Lumma malware dropped sharply, signifying an initial disruption in the infostealer ecosystem as pictured below.

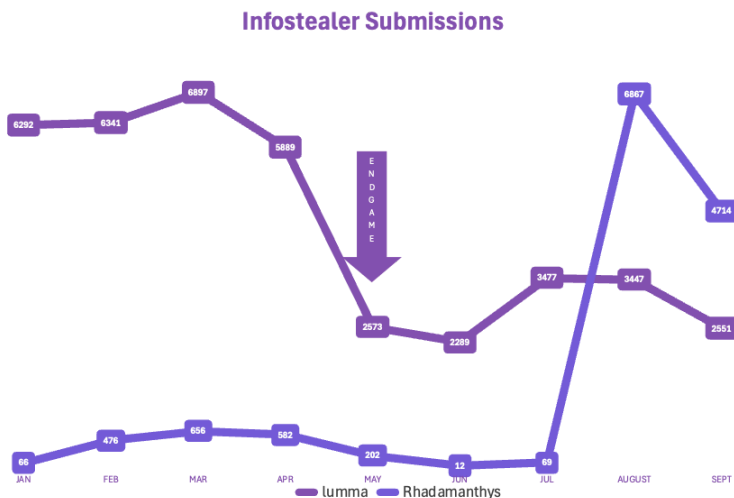
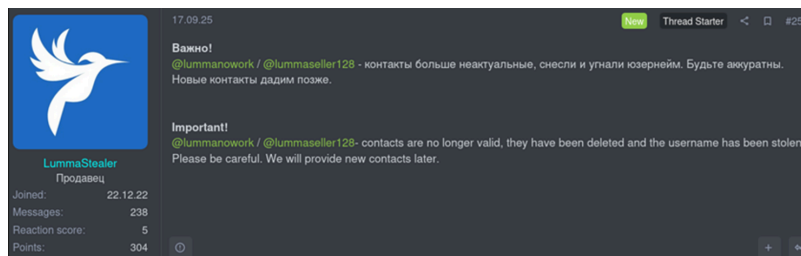


Figure 7: Infostealer Trending

Through ENDGAME, law enforcement delivered a big hit to Lumma Stealer in cybercriminal ecosystems. While we can't be certain of the exact impact, in criminal forums monitored by Beazley Security, Lumma admins communicated that nearly 2,500 of their domains were seized.

The speculation was that law enforcement had infiltrated their servers with “some internal vulnerability in IDRAC,” a built-in console that allows administrators to remotely manage the servers over a network. Lumma admins reported fixing and physically disabling the interfaces after the compromise. They also alleged that law enforcement crafted phishing pages to steal credentials, collect IP addresses, and requested access to Lumma customer webcams. Shortly after posting these details, the account “Lumma” was deactivated from the darkweb forum, which built skepticism amongst members about the legitimacy of the claims. Regardless, many consumers of the Lumma service lost confidence and moved their operations to other infostealer “platforms.”

On September 17th, Lumma Stealer telegram accounts, channels, and marketplace bot were taken down. On another criminal forum monitored by Beazley Security, Lumma admins stated they had lost control of the telegram accounts.



Caption of LummaStealer Post

As concern grew among threat actors using the infiltrated infostealer platform, the community started targeting individuals believed to be involved with development of Lumma Stealer. Beazley Security monitored an ongoing campaign against Lumma admins starting in late August, eventually resulting in a website called “Lumma Rats” being published. While Beazley Security cannot confirm legitimacy or motive, the site is alleged to have personally identifiable information (PII), financial records, passwords, and social media profiles of five Lumma Stealer operators.

Enter Rhadamanthys. This infostealer variant first appeared in underground forums in late 2022 and, with recent enhancements, is a considerably stealthy and effective infostealer. The group behind Rhadamanthys goes by “RHAD Security” and “Mythical Origin Labs” and has since provided threat actors with tiered malware-as-a-service (MaaS) offerings, including an “Enterprise Package” where customers can contact the group’s support and sales team for additional information and customization. The infostealer includes modern capabilities to evade detection and common analysis techniques used by defenders.

The surge in submissions for Rhadamanthys aligns with a few events, including significant enhancements to the infostealer in recent versions. The group expanded market presence beyond underground forum advertisements with a branded, professional-looking Tor site and Telegram support channels. The infostealer was also recently observed being chained in ClickFix delivery methods, a trending social engineering technique which tricks users into copy and pasting malicious PowerShell commands onto their system under the guise of fixing a technical issue solving a CAPTCHA.



While enforcement actions created disruption amongst major infostealer families and eroded confidence amongst consumers, the heavy adoption in Rhadamanthys signals the ongoing and continued demand for commoditized infostealers, and the spike in submission activity highlights the success of these services within cybercriminal ecosystems.

PXA Stealer Campaign Exposed

In partnership with SentinelLabs, Beazley Security Labs reported on a novel infostealer campaign this quarter, centered around a Python-based malware named PXA Stealer. This campaign, active from late 2024 through 2025, was linked a Vietnamese-speaking cybercriminal threat actor and impacted thousands of victims in at least 62 different countries, including the United States, South Korea, the Netherlands, Hungary, and Austria.

The campaign successfully harvested a large amount of sensitive data, including over 200,000 passwords, hundreds of credit card records, and more than 4 million browser cookies, illustrating the scale and effectiveness of the operation.

To avoid detection, the campaign leveraged several techniques to make forensic analysis difficult for defenders and researchers. These were in addition to the typical deception tricks threat actors use to hide malicious components from intended target users. Benign decoy documents disguised as business invoices or legal paperwork were used to appear as legitimate attachments, while malware abused DLL side-loading in legitimate applications like Microsoft Word to avoid detection and mislead analysts. If successfully executed, PXA stealer leveraged native Windows tooling to unpack and install the infostealer, allowing the malware to blend into the user's standard workflow.

Once the malware was installed, it began harvesting a range of sensitive information, including passwords, credit card details, screenshots, browser data, and cryptocurrency wallet information. The data was then exfiltrated from victim machines through Cloudflare relays and encrypted Telegram channels, demonstrating how attackers are abusing these common services to disguise exfiltration and reduce footprint. Telegram also allowed the actor to quickly package and sell stolen data on underground cybercriminal marketplaces.

While investigating the threat actor's operation, the combined team of researchers at SentinelOne and BSL discovered the threat actor had run PXA stealer on one of their own personal development computers and, as a result, were able to obtain visible login and password data sourcing from the threat actor's compromised machine. This gave the research team a very rare peek "behind the scenes" into a large amount of the tooling, techniques, and back-end infrastructure PXA stealer was using in the development and deployment of their malware campaign. For more insight into the data we were able to collect due to this threat actor's mistake, read part two of our PXA Stealer blog: [Chasing a Ghost: PXA Stealer Part 2](#).



Ultimately, this campaign demonstrates how threat actors effectively leverage trusted software, familiar file types, and established platforms in efforts to bypass endpoint detection solutions and mislead experienced security analysts. It also underscores how cybercriminals continuously refine their tactics and techniques to scale operations. The complexity and sophistication of their attacks serve as a reminder for organizations to adopt robust cybersecurity practices and stay ahead of evolving threats.

For additional information regarding PXA stealer, review part one of our PXA Stealer series on the Beazley Security Labs blog: [Ghost in the Zip | New PXA Stealer and its Telegram-Powered Ecosystem](#).

Q3 Security Challenges for SonicWall

A series of events impacted SonicWall clients and services in Q3, with repercussions continuing through the time of this reporting. In early August, security teams began observing a large number of Akira ransomware deployments ultimately linked to SonicWall VPN compromises. Due to the widespread reporting of incidents, security researchers began raising concerns around the potential of a new 0-day exploit being weaponized by the ransomware group.

As a result, SonicWall released an advisory to acknowledge the campaign and launched an investigation into the matter. Initially, SonicWall provided few details, reporting only that the investigation was ongoing and instructing organizations using the firewalls to review logs, watch for suspicious activity, and disable or limit SSLVPN services to trusted networks. As new information surfaced, the vendor released a series of incident updates throughout the quarter.

The following timeline summarizes key developments throughout Q3 2025:

TIMELINE OF KEY SONICWALL EVENTS

Vulnerability Disclosure

August 8, 2024: CVE-2024-40766 vulnerability affecting SonicWall VPN devices released, acknowledging improper access controls.

SSLVPN Campaign Advisory

August 4, 2025: Advisory issued warning of an ongoing campaign targeting VPN on SonicWall Firewalls to gain unauthorized access.

Ransomware Attribution

August 7, 2025: Advisory updated attributing the campaign to Akira ransomware group targeting CVE-2024-40766 with credential stuffing attacks.

Cloud Service Incident

September 17, 2025: Less than 5% of firewall configurations backed up to MySonicWall compromised in cloud incident.

Data Compromise Conclusion

October 8, 2025: Investigation concludes **all backup** service users had configuration data compromised.



By mid-August, SonicWall updated the campaign advisory with a "high confidence" assessment that the activity was not related to an undisclosed vulnerability, but rather exploitation of a previously released flaw regarding weak access controls dating back to August 2024. The advisory was updated attributing the old vulnerability (CVE-2024-40766), which had previously been exploited by Akira. Although details remained limited, SonicWall's advisory on the matter maintains the campaign was limited to fewer than 40 incidents, many linked to firewall migrations where legacy passwords were not reset on the appliances. Security researchers believe Akira ransomware operators had been using large scale, automated credential stuffing attacks to gain initial access on SonicWall devices with weaker configurations to deploy ransomware.

In mid-September SonicWall disclosed a [data breach involving their MySonicWall cloud backup service](#). The cloud service can be used by customers who opt in as a way to store and backup sensitive firewall configurations. The vendor originally disclosed that a threat actor accessed firewall configuration backups for a small subset of customers, stating less than 5% of stored configuration backups may have been compromised. The backup files contained device configurations, VPN setup data, and encrypted administrative credentials.

As the investigation continued, **SonicWall revised its findings and later revealed that all users of the MySonicWall backup service were affected** meaning the attackers had compromised sensitive configuration files from every customer using the service.

While any connection between Akira's widely successful SonicWall VPN campaign and subsequent MySonicWall cloud service breach cannot be established at this time, the events have left an overlapping threat to customers using SonicWall's network appliance product line. Going forward, Beazley Security expects threat actors in possession of the stolen configurations will leverage the compromised backup files to launch future, targeted attacks.

Sources

- <https://labs.beazley.security/advisories/BSL-A1109>
- <https://labs.beazley.security/advisories/BSL-A1118>
- <https://labs.beazley.security/advisories/BSL-A1125>
- <https://labs.beazley.security/advisories/BSL-A1138>

- <https://labs.beazley.security/articles/ghost-in-the-zip-or-new-pxa-stealer-and-its-telegram-powered-ecosystem>
- <https://labs.beazley.security/articles/chasing-a-ghost-pxa-stealer-part-2>
- <https://operation-endgame.com/news/>
- <https://www.sonicwall.com/support/product-notification/product-notice-sslvpn-and-ssh-vulnerability-in-sonicos/250107100311877>
- <https://www.sonicwall.com/support/notices/gen-7-and-newer-sonicwall-firewalls-sslvpn-recent-threat-activity/250804095336430>
- <https://www.sonicwall.com/support/knowledge-base/mysonicwall-cloud-backup-file-incident/250915160910330>
- <https://labs.withsecure.com/publications/tamperedchef>
- https://www.trendmicro.com/en_us/research/25/i/evilai.html
- <https://www.cisa.gov/news-events/directives/ed-25-03-identify-and-mitigate-potential-compromise-cisco-devices>
- <https://blog.checkpoint.com/executive-insights/hexstrike-ai-when-llms-meet-zero-day-exploitation/>
- <https://www.comparitech.com/news/ransomware-gang-says-it-hacked-pennsylvanias-attorney-general/>
- <https://www.reuters.com/world/asia-pacific/cybercriminals-claim-hack-japans-asahi-group-2025-10-07/>



More Insights

[View All >](#)

Quarterly Threat Report

Quarterly Threat Rep



Third-Party Risk Monitoring Factsheet

Beazley Security's
Third-Party Risk Monitori...

Quarterly Threat Report: First Quarter, 2026

The first quarter of 2026
started with a lull and...

Quarterly T Report: For Quarter, 20

A majority of rans
activity resulted i



beazley security

[Solutions](#)

[Company](#)

[Resources](#)

[Beazley
Clients](#)

[Contact
us](#)



Privacy Policy

©2026 Beazley Security is a wholly owned subsidiary of Beazley plc, providing cyber security services. Beazley Security does not provide insurance products or services, nor does it provide legal services or advice. Customer information may be shared between Beazley Security and Beazley plc and/or its affiliates and subsidiaries; however, such information will not be used to inform the underwriting or claims decisions of any Beazley insurance affiliate, unless the customer agrees to disclose such information for that purpose.